

Passwords

Weak or reused passwords are the single most common cause of account compromise. This guide covers everything from creating strong passwords to setting up the most secure forms of multi-factor authentication.

STRONG PASSWORDS

Use long, complex passwords (16+ characters)

CRITICAL

Applies to all accounts

Why it matters: Password cracking tools can test billions of combinations per second. An 8-character password can be brute-forced in hours. A randomly generated 16-character password with mixed characters would take centuries with current technology. Length matters far more than complexity alone.

Steps:

1. For passwords you need to memorize (like your password manager master password), create a passphrase with 4-5 words plus a number and symbol. Example: **correct-horse-battery-staple7!**
 2. For everything else, let your password manager generate a random password of at least 16 characters with uppercase, lowercase, numbers, and symbols
 3. Never use personal information in passwords - birthdays, names, pet names, or addresses are easy to guess or find through data breaches
 4. Check if any of your passwords have appeared in known data breaches at **haveibeenpwned.com**
-

UNIQUE PASSWORDS

Never reuse passwords across accounts

CRITICAL

Applies to all accounts

Why it matters: When a company suffers a data breach, attackers immediately try stolen credentials on other major services - email, banking, social media. This is called credential stuffing. If you reuse passwords, one breach compromises all of them. Billions of username/password combinations from past breaches are freely available online.

Steps:

1. Every single account should have a different password - no exceptions for 'unimportant' sites. Even a low-stakes account can be used to reset passwords elsewhere
2. Use a password manager to generate and store unique passwords - there's no need to memorize them
3. Visit **haveibeenpwned.com** and enter your email addresses to see which breaches have exposed your credentials - then update those passwords immediately

PASSWORD MANAGER

Set up a dedicated password manager

CRITICAL

Replaces browser-saved passwords

Why it matters: Browser-saved passwords are riskier - they can be exported or accessed by malware, and they're tied to your Google or Apple account. A dedicated password manager encrypts your vault locally before syncing, meaning the provider never has access to your passwords.

Steps:

1. Pick a password manager - **Bitwarden** (free, open source) or **1Password** (paid, excellent UI) are the top recommendations
 2. Create an account and set a strong master password - this is the one password you must memorize. Use a long passphrase. Write it down somewhere physically secure until you've memorized it
 3. Install the browser extension and mobile app
 4. Import any passwords saved in your browser: in Chrome go to **Settings → Passwords → Export**, then import the file into your password manager
 5. As you log into sites going forward, let the password manager save and auto-fill credentials. Gradually update old weak or reused passwords using the manager's built-in generator
-

PASSKEYS

Enable passkeys wherever supported

CRITICAL

Account security settings on supported sites

Why it matters: Passkeys use public-key cryptography - a unique key pair is generated for each site, and your private key never leaves your device. They cannot be phished, cannot be leaked in a data breach, and don't require you to type anything. They're resistant to every major attack vector that threatens traditional passwords.

Steps:

1. When a site offers 'Sign in with a passkey' or 'Create a passkey', always choose it over a traditional password
2. On iPhone: passkeys are saved to your iCloud Keychain automatically. On Android: they're saved to Google Password Manager or a third-party manager like Bitwarden
3. Major services that support passkeys include Google, Apple, Microsoft, GitHub, and PayPal. Check **passkeys.directory** for a full list
4. Even after enabling a passkey, keep a strong backup password in your password manager in case you need it

MFA - SECURITY KEY (BEST)

Set up a hardware security key (YubiKey)

CRITICAL

Account security settings on supported sites

Why it matters: A hardware security key is a physical device that you plug in or tap to authenticate. Because the key must be physically present, remote attackers cannot access your account even if they have your password. It is completely immune to phishing - you cannot be tricked into handing over your second factor over the phone or via a fake website.

Steps:

1. Purchase a YubiKey from **yubico.com**. The YubiKey 5 NFC works with both USB-A and NFC for phones. Buy two - keep one as a backup
 2. Register your key on your most critical accounts first: Google, Apple ID, Microsoft, GitHub, and your password manager
 3. For Google: go to **myaccount.google.com → Security → 2-Step Verification → Add security key**
 4. Store your backup key in a physically secure location - not with your primary key
-

MFA - AUTHENTICATOR APP (RECOMMENDED FOR MOST)

Install an authenticator app and enable it everywhere

CRITICAL

Account security settings → Two-factor authentication

Why it matters: An authenticator app generates a time-based one-time code (TOTP) that changes every 30 seconds and is tied to your specific device. Even if an attacker has your username and password, they cannot log in without also having physical access to your phone. Unlike SMS codes, these cannot be intercepted via SIM swapping.

Steps:

1. Download **Proton Authenticator** (best privacy) or **Aegis** (Android, open source) or **Raivo** (iOS, open source)
2. On each account, go to **Security settings → Two-factor authentication → Authenticator app**
3. Scan the QR code shown with your authenticator app - this links the app to your account
4. Save the backup/recovery codes the site provides in your password manager vault
5. Enable on every account that supports it. Priority order: email → bank → password manager → Apple/Google account → social media

MFA - SMS / EMAIL OTP (USE AS LAST RESORT)

Understand the risks of SMS-based MFA

HIGH

Applies when SMS is your only MFA option

Why it matters: SMS codes are vulnerable to SIM swapping - where an attacker convinces your carrier to transfer your phone number to a SIM card they control. They then receive your MFA codes. This attack has been used to drain cryptocurrency accounts and take over high-value social media profiles.

Steps:

1. If a site only offers SMS MFA, enable it - it's still significantly better than no MFA at all
 2. Whenever a site later adds authenticator app or hardware key support, switch to it immediately
 3. Call your mobile carrier and ask them to add a PIN or passphrase requirement before any account changes can be made - this makes SIM swapping harder
 4. Make sure notification previews are disabled on your lock screen so SMS codes aren't visible to anyone who picks up your phone
-

PRIORITY ACCOUNTS TO SECURE FIRST

Secure your highest-value accounts first

HIGH

Account security settings

Why it matters: Your email account is the master key to everything else - most password resets are sent there. Your Apple ID or Google account controls access to your phone, photos, and backups. Compromising either of these gives an attacker a foothold to take over your entire digital life.

Steps:

1. Priority 1 - Critical: **Email** (Gmail, ProtonMail). Controls password resets for every other account
2. Priority 2 - Critical: **Apple ID / Google account**. Controls your phone, backups, and app purchases
3. Priority 3 - Critical: **Password manager**. Controls access to all your other credentials
4. Priority 4 - High: **Banking & financial accounts**. Direct financial risk if compromised
5. Priority 5 - High: **Social media**. Identity theft and impersonation risk
6. Priority 6 - Medium: **Everything else**. Any account can be a stepping stone to higher-value ones